Content

History of Changes in documented information 1

Access Control hardening 2

Database hardening 2

Network hardening 2

Server Configuration hardening 2

Server Security Monitoring and Protection 3

History of Changes in documented information

Date	Created by	ID	Version	Change
22.04.2020.	Hrvoje Kovačević	HS	1.0	Initial document created
28.05.2021	Hrvoje Kovačević	HS	1.1	Update

Mindsmiths	Hardening Standard			
	ID	HS	**Author**	Hrvoje Kovačević
	Version	1.1	**Date**	28.05.2021.

Access Control hardening

1. Where possible access controls to files, data and applications follow a role-based model.
2. Unneeded user accounts should be removed from the system.
3. Elevated privileges are not granted to non-administrative accounts. Tools such as “sudo” may be used to temporarily elevate privileges of user accounts.
4. Where possible administrative accounts are linked to a single individual or service.
5. Shared administrative accounts have their passwords and use restricted and protected to the fullest extent possible.
6. Passwords must adhere to the Mindsmiths Password Policy.
7. Where possible automatic idle time-out log-off of administrative users sessions must be set to 15 minutes.

Database hardening

1. All data leaving the databases will be encrypted.
2. All databases will be protected by a secure password even if inside of a safe network.
3. Automatic dumps will be created for each database in the production environment.
4. Audit logs will be gathered and made available for inspection for each database in the production environment.
5. Query logs will be gathered and made available for inspection for each database in the production environment.

Network hardening

1. Firewalls will be used in front of every network.
2. Physical access to the firewall will be restricted, behind a locked door.
3. Firewall configuration must adhere to Mindsmiths Firewall Policy.
4. Firewall configuration auditing will be performed either annually or according to the vendor’s recommendation.
5. Unnecessary network ports will be blocked. All ports not required by the service explicitly used for client’s or organization’s needs are deemed unnecessary.
6. Anonymous access will be disallowed.
7. The firewall solution will offer AntiVirus/Malware protection
8. The firewall solution will offer IPS/IDS protection.

Mindsmiths	Hardening Standard			
	ID	HS	**Author**	Hrvoje Kovačević
	Version	1.1	**Date**	28.05.2021.

Server Configuration hardening

1. The server is protected with a network firewall at the edge of its network.
2. Firewall rules are whitelist based.
3. Remote access is disabled for built-in privileged system accounts such as root and Administrator.
4. All hosts (laptops, workstations, mobile devices) used for system administration are secured as follows:
    a. Secured with an initial password-protected log-on and authorization,
    b. Whole disk encryption required on portable devices,
    c. Whole disk encryption is required on desktop workstations,
    d. Separate local admin and user accounts,
    e. Up to date VPN software,
    f. Regular, timely, OS, and software updates.
5. The OS installed on the server has been installed by the system administrator.
6. Only software necessary for the server's primary function has been installed and enabled on the server.
7. OS and software patching will be performed either monthly or according to the vendor's patch release schedule.
8. If used, private keys used in public-private key pairs of asymmetric cryptography are only available to the individual associated with the private key's identity or an operational group responsible for the service.
9. Server Data is properly backed up to another system.

Server Security Monitoring and Protection

1. Logs are collected and monitored for security-related events.
2. Logs are replicated on a system other than the server generating the logs.
3. Security-related events are reported to the Information Security Office.
4. Audit trails of security-related events are retained.
5. The server will be scanned for vulnerabilities on a monthly basis and address in a timely manner.